



LGPD

Lei Geral de Proteção de Dados Pessoais
(Lei nº 13.709/2018)

Prof.: Jósis Alves

Segurança e Sigilo de Dados na LGPD

Análise Normativa e Aplicação Prática dos Artigos 46 a 49

Da Segurança e do Sigilo de Dados: Art. 46

Art. 46. Os agentes de tratamento devem adotar medidas de segurança, técnicas e administrativas aptas a proteger os dados pessoais de acessos não autorizados e de situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou qualquer forma de tratamento inadequado ou ilícito.

§ 1º A autoridade nacional poderá dispor sobre padrões técnicos mínimos para tornar aplicável o disposto no caput deste artigo, considerados a natureza das informações tratadas, as características específicas do tratamento e o estado atual da tecnologia, especialmente no caso de dados pessoais sensíveis, assim como os princípios previstos no caput do art. 6º desta Lei.

§ 2º As medidas de que trata o caput deste artigo deverão ser observadas desde a fase de concepção do produto ou do serviço até a sua execução.



Medidas Técnicas

Ações aplicadas na infraestrutura e nos sistemas operacionais.

Exemplo: Criptografia de banco de dados, firewalls corporativos, autenticação de múltiplos fatores (MFA) para acesso a sistemas, controle rigoroso de logs.



Medidas Administrativas

Ações focadas em governança, processos e comportamento humano.

Exemplo: Treinamento de conscientização de funcionários, políticas de mesa limpa, termos de confidencialidade (NDA), auditorias internas periódicas.



Privacy by Design (§ 2º)

A segurança como requisito fundacional, não como um adendo pós-lançamento.

Exemplo: Um novo aplicativo de RH já deve ser desenhado (codificado) com restrição de acesso a dados de saúde ativada por padrão antes do seu lançamento.

Da Segurança e do Sigilo de Dados: Art. 47

Art. 47. Os agentes de tratamento ou qualquer outra pessoa que intervenha em uma das fases do tratamento obriga-se a garantir a segurança da informação prevista nesta Lei em relação aos dados pessoais, mesmo após o seu término.

Durante o Tratamento

Obrigações plenas de segurança e sigilo durante a prestação do serviço ou vigência contratual.

Mesmo Após o Término

O fim do contrato ou do consentimento **NÃO** extingue o dever de proteger os dados.

- **Exemplo de Guarda Obrigatória:** Uma clínica médica guarda o prontuário de um paciente por 20 anos (norma do CFM). Durante todo esse tempo, o servidor exige proteção contínua contra vazamentos.
- **Exemplo de Descarte Seguro:** Se a finalidade acabou, o descarte deve ser auditável (ex: trituração de papel nível P-4, wiping certificado de discos rígidos em vez de apenas enviar para a lixeira).

Da Comunicação de Incidentes: Art. 48 (Caput e § 1º)

Art. 48. O controlador deverá comunicar à autoridade nacional e ao titular a ocorrência de incidente de segurança que possa acarretar risco ou dano relevante aos titulares.

§ 1º A comunicação será feita em prazo razoável, conforme definido pela autoridade nacional, e deverá mencionar, no mínimo:

- I - a descrição da natureza dos dados pessoais afetados;
- II - as informações sobre os titulares envolvidos;
- III - a indicação das medidas técnicas e de segurança utilizadas para a proteção dos dados, observados os segredos comercial e industrial;
- IV - os riscos relacionados ao incidente;
- V - os motivos da demora, no caso de a comunicação não ter sido imediata; e
- VI - as medidas que foram ou que serão adotadas para reverter ou mitigar os efeitos do prejuízo.

Comentários e Exemplos: Art. 48 (Caput e § 1º)

O Gatilho da Comunicação

Nem todo incidente é reportável à ANPD. Apenas aqueles que geram risco ou dano relevante (fraude, roubo de identidade, exposição de dados sensíveis).

Exemplo: Um ataque de Ransomware criptografando bancos de dados produtivos, ou a perda de um pen drive não-criptografado contendo a folha de pagamento no transporte público.

Checklist de Resposta Rápida (O que informar?)

- ☐ O que vazou? (Nomes, CPFs, cartões, dados médicos?)
- ☐ De quem? (Clientes, funcionários, menores de idade?)
- ☐ Como estávamos nos protegendo? (Sem revelar arquitetura confidencial/segredo de negócio)
- ☐ Qual o risco agora? (Os titulares podem sofrer golpes?)
- ☐ Por que demoramos a avisar? (Aplicável se não for notificação imediata)
- ☐ O que estamos fazendo para consertar? (Monitoramento ativado, reset forçado de senhas)

Ações da Autoridade Nacional: Art. 48 (§ 2º e § 3º)

§ 2º A autoridade nacional verificará a gravidade do incidente e poderá, caso necessário para a salvaguarda dos direitos dos titulares, **determinar** ao controlador a adoção de providências, tais como:

- I - ampla divulgação do fato em meios de comunicação; e
- II - medidas para reverter ou mitigar os efeitos do incidente.

§ 3º No juízo de gravidade do incidente, será avaliada eventual comprovação de que foram adotadas medidas técnicas adequadas que tornem os dados pessoais afetados **ininteligíveis**, no âmbito e nos limites técnicos de seus serviços, para terceiros não autorizados a acessá-los.

Comentários e Exemplos: Art. 48 (§ 2º e § 3º)



Dano Reputacional Direcionado (§ 2º)

A ANPD possui o poder impositivo de tornar pública a falha da empresa, priorizando o alerta ao cidadão sobre a imagem corporativa.

Exemplo: A autoridade obriga a empresa a comprar espaço em jornais de grande circulação ou colocar um banner irremovível na homepage do seu site dizendo: Sofremos um vazamento de dados, clique aqui para saber se você foi afetado.



O Salva-Vidas da Ininteligibilidade (§ 3º)

Se os dados vazados estiverem em um formato impossível de ser lido pelos criminosos (ininteligível), a gravidade jurídica do incidente despenca, evitando as sanções de publicidade.

Exemplo de Mitigação: Ladrões furtam fisicamente um servidor. Contudo, o disco rígido possuía criptografia de nível militar AES-256. Sem a chave-mestra, os dados são lixo digital. A empresa prova isso à ANPD e não é obrigada a expor o caso ao público.

Estrutura e Governança: Art. 49

Art. 49. Os sistemas utilizados para o tratamento de dados pessoais devem ser estruturados de forma a atender aos requisitos de segurança, aos padrões de boas práticas e de governança e aos princípios gerais previstos nesta Lei e às demais normas regulamentares.

Adequação LGPD Contínua

Estrutura de Sistemas

Arquitetura de TI construída para rastreabilidade (auditability).

Exemplo:
Aplicações com audit trails imutáveis que registram qual usuário acessou qual tabela do banco de dados, em qual dispositivo e a que horas.

Padrões de Boas Práticas

Adoção e aderência a normas validadas pelo mercado global.

Exemplo:
Implementação de controles rígidos baseados na família ISO/IEC 27000 (Gestão de Segurança da Informação) e ISO 27701 (Privacidade da Informação).

Governança

Políticas vivas, métricas e liderança de carne e osso envolvida no tema.

Exemplo:
Nomeação ativa do Encarregado de Dados (DPO), criação de um Comitê de Privacidade interno e elaboração rotineira de Relatórios de Impacto (RIPD).

Síntese Executiva: O Framework de Segurança (Arts. 46 a 49)

Fase Operacional	Dever Legal	Mecanismo Prático
Pré-Lançamento (Desenvolvimento)	Art. 46 (§ 2º): Privacy by Design	Embutir restrições de segurança nativas na concepção inicial da arquitetura do produto.
Operação Contínua (Dia a Dia)	Arts. 46 e 49: Medidas, Boas Práticas e Governança	Monitoramento de redes, certificações ISO, políticas corporativas e cultura de proteção.
Durante a Crise (Incidente)	Art. 48: Resposta a Incidentes	Notificação tempestiva, plano de contenção de danos e prova de ininteligibilidade técnica (dados criptografados salvando a reputação).
Pós-Ciclo de Vida (Fim de Contrato)	Art. 47: Segurança Estendida	Garantia inegociável de retenção selada (guarda legal) ou descarte irreversível e certificado.

1) Ano: 2024 Banca: Quadrix Órgão: COREN-PR Prova: Quadrix

Os agentes de tratamento devem adotar medidas de segurança, técnicas e administrativas aptas a proteger os dados pessoais de acessos não autorizados e de situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou qualquer forma de tratamento inadequado ou ilícito.

2) Ano: 2026 Banca: FUNATEC Órgão: Prefeitura de São José do Divino - PI

Nos termos da Lei Geral de Proteção de Dados Pessoais (LGPD), o artigo 48 estabelece obrigações específicas ao controlador em caso de incidente de segurança envolvendo dados pessoais.

Com base nesse dispositivo legal, assinale a alternativa correta:

- A) O controlador deve comunicar à autoridade nacional e aos titulares a ocorrência de incidente de segurança que possa acarretar risco ou dano relevante aos titulares.
- B) A comunicação do incidente de segurança ao titular é facultativa e condicionada à solicitação expressa da autoridade nacional.
- C) O controlador deve comunicar a ocorrência de incidente de segurança exclusivamente à autoridade nacional, independentemente de risco ou dano aos titulares.
- D) A obrigação de comunicação do incidente de segurança recai exclusivamente sobre o operador, por ser o responsável direto pelo tratamento dos dados.

GABARITO

1 - certo

2 - A